LEXIGRID

Risk Reporting and Enterprise IRM

Version 5.54.15 | Reviewed 2026-11-11

Shahryar Jahangir, Aniza Inc.

Procedures, examples, verification and operational limits. Complete commissioning on your deployment before serving customer traffic. Sample values are fictional; original keys and data must be preserved.

Contents

Risk Reporting and Enterprise IRM 3

- Risk reporting . . . 3
- Enterprise IRM . . . 3
- AI proposal provenance . . . 4
- AI review and official ratings . . . 4

Workflow decisions and delivery recovery 4

- Review a governed record . . . 4
- Inbox and overdue checks . . . 4
- Channel retry and manual recovery . . . 4
- Exact content and author independence . . . 5

Risk assessment methodologies and reports 5

- Perform a single-risk or batch assessment . . . 5
- Available methodology profiles . . . 6
- FAIR quantitative assumptions and output . . . 6
- Export contents and interpretation . . . 7
- Official references . . . 7
- Deployment and runtime behavior . . . 7

Risk change history and independent remediation closure 7

- View risk changes . . . 7
- Close a remediation with an independent review . . . 8

Risk acceptance, expiry and independent approvals 8

- Request bounded risk acceptance . . . 9
- Independently decide or revoke . . . 9
- Expiry and re-review . . . 9
- Edit, close and AI assessment . . . 10
- Native approvals and generic workflows . . . 10
- Audit control-owner independence . . . 10
- API . . . 10

Risk Reporting and Enterprise IRM

Risk reporting

Navigate to **Reports**, select filters, and choose **Run report**. The report displays the risk owner (accountable business owner), the user who created the risk, the last user to update or close it, the latest recorded approving user, approval status, and the user who closed it if the risk is currently closed. Reopening clears the current closure attribution while keeping earlier closure events in the activity history. **Export CSV**, **Export XLSX** and **Export PDF** include these fields. API `GET /api/reports/risks` also includes per-risk `approvals` and `activity_history` arrays for deeper review. Actor names resolve to tenant user emails where available. Older events without matching audit records display blank attribution; do not treat blank as evidence that no action occurred.

An approval is recorded only when the risk approval workflow has a formal approved decision. Risk closure is tracked separately and is not itself evidence of an approval. Ordinary reports are scoped to the signed-in tenant. Platform administrators may use the separate Platform risk report panel to explicitly select organizations and export JSON, CSV, XLSX or PDF. The selection, actor, format and record count are audited in the caller organization. Tenant administrators and other roles cannot use that endpoint.

API: GET /api/reports/risks.xlsx and /api/reports/risks.pdf accept the same filters as the JSON report. GET /api/platform/reports/risks requires one or more tenant_ids parameters (at most 50) and an optional format=json|csv|xlsx|pdf. Unknown organizations are rejected. Spreadsheet text is stored as text to prevent formula execution; unsupported XML control characters are replaced. Excel limits cell text to 32,767 characters; use JSON for complete activity history. PDF reports contain the flat attributed record fields; JSON also preserves nested approvals and activity history.

Enterprise IRM

Enterprise IRM means *Integrated Risk Management*. The workspace is a general-purpose register for governance and assurance records beyond the main Risks screen: assets, business impact analyses, continuity plans, control tests, regulatory obligations and changes, vendor assessments, questionnaires, audit engagements and workpapers, findings, exceptions, key risk indicators, risk appetite, resilience exercises, evidence reviews, and more.

Using it

1. Open **Enterprise IRM** from the left navigation.

2. Choose a record type from the dropdown. The screen displays existing records of that type.

3. Select **Create record**, enter its title, owner, and the required fields, and save.

4. Select **Review** on an existing record to advance it to its next permitted lifecycle state, entering a justification.

5. Certain significant transitions require a completed approval workflow: configure and publish a definition in **Workflows**, start a workflow for the target record and target state, have the assigned approver decide, then retry the transition.

6. Use the regular **Risks** workspace for operational risk creation, scoring, AI assessment, closure, and the risk portfolio report.

Examples

- **Obligation:** record a regulatory requirement, owner, and citation; manage its lifecycle.

- **Control test:** schedule a test, capture method and tester, and track pass/fail states.

- **Exception:** record a control exception, justification, expiration, and approver.

- **Business impact:** track a service's recovery time and recovery point objectives.

Current limitations: The Enterprise IRM screen is a generic record editor, not a full specialized UI for each type. It does not automatically cross-link all records to risks, nor does the standard Risk Report include every enterprise record. The generic review button advances one lifecycle state at a time; approval workflow gates can prevent a transition until authorization is complete.

AI proposal provenance

Generate proposals in the risk assessment panel. The generic Enterprise IRM editor preserves access to the existing review workflow and does not create or change AI proposal payloads. The risk panel displays generated scores and rationale when the saved payload matches the digest recorded by the assessment endpoint. Older proposals without a matching audit digest remain available in Enterprise IRM and are labeled as unverified in the risk panel. Provenance identifies the recorded origin of a proposal. Reviewers still evaluate the evidence and decide whether to act on it.

AI review and official ratings

Enterprise IRM Review on an AI recommendation opens its risk assessment panel. Generate proposals through the risk workspace; choose Keep current assessment or Apply AI assessment and confirm. Successful adoption changes the official likelihood/impact and increments the risk version, so the risk register, dashboard and reports read the updated rating. A residual assessment and the actual deciding user are recorded, while original proposal authorship is retained. Existing formal proposal workflows remain content-bound. The model does not automatically change a risk or complete a treatment.

Workflow decisions and delivery recovery

Review a governed record

Create/publish a workflow definition with designated approvers and optional due dates. Start a run for the exact record and target state. A run snapshots approver steps and the reviewed content digest/version. The initiator cannot approve their own run, and only the assigned approver can decide a step. A stale version or resolved run is a conflict, not permission to repeat an approval.

After required decisions complete, retry the governed transition. Approval consumption and transition are atomic and single-use. Changing material record content invalidates the prior approval. An unrelated/legacy approval does not authorize the transition. Check decision history for the actual step and actor, not merely the final state label.

Inbox and overdue checks

The workflow inbox shows the user's own notifications and channel status. Mark read records reading in the application; it is not SMTP delivery confirmation. Tenant administrators may trigger overdue checks. The independent scheduler runs periodic escalation/delivery; native startup alone does not install that scheduler.

Channel retry and manual recovery

Enabled webhook/email channels have separate durable states: queued, sending, retry, retry_requested, failed or delivered. Automatic delivery stops after five attempts, using 2/4/8/16-minute failure backoff and a ten-minute lease. A successful channel is not resent when another channel fails. Disabled channels keep their state until re-enabled.

After correcting the transport issue, a permitted tenant administrator/risk manager may use Failed workflow deliveries to request one additional attempt with a reason and current attempts. Platform administrators act within the selected tenant. A stale/concurrent request returns 409; refresh first. Attempts never reset, and the retry event is audited in the same transaction.

An expired sending lease can mean remote acceptance already occurred. Message-ID/Idempotency-Key stays stable, but the guarantee is at least once. Use receiver deduplication and inspect gateway evidence before manually retrying a suspected accepted message. Do not delete failures or rewrite audit history to hide retries.

Exact content and author independence

, creators, recorded editors and identified owners cannot approve the target through another workflow initiator. Each approval step rechecks the reviewed content digest/version before deciding, in addition to the existing check before consumption. Reject a stale pending run and start a fresh review. Native risk/policy/finding requests also carry exact-content bindings; stale or legacy unbound approvals cannot authorize new actions. Risk acceptance has its own independent decision and mandatory UTC expiry in the Risk Acceptance workspace.

Risk assessment methodologies and reports

Author: Shahryar Jahangir, Aniza Inc.

Perform a single-risk or batch assessment

1. Open **Risk Assessment** from the navigation menu. Select an assessment methodology. Read its scope notice and official reference link.

2. Select one or more defined risks, with no fixed risk-count ceiling. Previous/Next pages retain the selection; Clear selection resets it. Risks remain within the current workspace.

3. Expand each selected risk's scenario inputs. Provide scope, relevant assets, threat scenarios, vulnerabilities, organization acceptance criteria and sector details. Treat these entries as assertions; link control tests and other records from the risk to supply supporting evidence.

4. For FAIR, optionally provide every financial factor range and its estimation basis as described below. Leave all financial inputs blank to receive a missing-data analysis without invented monetary estimates.

5. Select **Assess selected risks**. Keep the page open while each selected risk is processed by the configured AI provider. The selected methodology is different from the language model: provider/model and air-gapped/cloud controls remain administrator settings.

6. Review the saved report's status, per-risk findings, confidence, evidence checks, gaps and proposed treatment. Failed or stale items are explicitly marked; retry those risks after resolving the cause. Successful risks remain available in partial reports.

7. Download JSON, PDF or CSV from the report. Saved reports preserves the assessment-time snapshot; later edits do not rewrite it. The most recent 100 reports are listed.

8. To accept a successful risk's proposed ordinal rating, select **Review rating: Keep or Apply**. This opens the shared review panel without running a different assessment. It identifies the methodology and offers Keep current assessment or Apply AI assessment. Apply requires explicit confirmation and rechecks current risk/evidence versions, provenance, permissions and any bound approval workflow. Financial estimates and proposed treatments remain advisory. Historical reports continue to show their original official-rating snapshot after adoption.

Risk administrators, managers and editors may run assessments. Other authenticated workspace members may read and export saved reports. Each creation, proposal, adoption decision and export is audited; errors retain request references. No rating changes merely because a report was generated or downloaded.

Available methodology profiles

Methodology	Analysis performed	Scope and limits
NIST SP 800-30 Rev. 1	Threat sources/events, vulnerabilities and predisposing conditions, event and adverse-impact likelihood, impacts, uncertainty and monitoring	Structured qualitative profile using LexiGrid's disclosed five-point scale. NIST does not prescribe one universal ordinal product matrix.
FAIR / Open FAIR	Loss scenarios, threat-event frequency, vulnerability probability, primary/secondary loss and data quality, plus reproducible range calculation	User-supplied quantitative factors are required for money estimates. This is a LexiGrid implementation of FAIR concepts, not a certified Open FAIR tool.
ISO/IEC 27005:2022	Context/criteria, asset-threat-vulnerability scenarios, identification, analysis, evaluation, treatment, communication and review	Organization criteria must be supplied. No licensed standard text or conformity assertion is included.
HHS Security Risk Assessment	ePHI assets/vendors, administrative, physical and technical safeguards, threats, impacts and remediation	HHS SRA-informed analysis; not the official SRA application, exhaustive questionnaire or HIPAA compliance determination.
FFIEC CAT (legacy)	Inherent-risk considerations and the five cybersecurity maturity domains, with evidence gaps	FFIEC retired CAT on August 31, 2025. A selected-risk report cannot determine institution-wide CAT maturity.
CISA Infrastructure Survey / resilience screening	Facility threat scenarios, physical protections, security management, dependencies, cascading impacts, recovery and missing observations	IST-informed desk screening. It does not conduct a site inspection, official CISA survey, peer comparison or protective/resilience index.
CISA Cybersecurity Performance Goals	IT/OT scope, governance/identification, protection, detection, response, recovery and prioritized outcomes	CPG-informed analysis rather than an official CSET module or complete CPG checklist. Validate proposed mappings against the current publication.

Every profile requires its own analysis sections. The server rejects incomplete structured responses after one retry, rather than presenting generic text as a successful methodology assessment. AI statements and mappings require review against the cited records; file metadata and assertions are not verified effectiveness. Unsupported reductions in current likelihood or impact are held at the existing rating. The unadjusted model estimate is separately retained.

FAIR quantitative assumptions and output

For each risk, enter a three-letter currency code and low / most likely / high values for: threat events per year; vulnerability (probability a threat event becomes a loss, from zero to one); primary loss per event; probability of secondary loss (zero to one); and secondary loss when it occurs. Include the data sources, observation period and assumptions in the basis field. All ranges must be ordered and nonnegative. Zero is a valid value. Partial ranges are rejected. Different risks may use different assumptions or currencies; the product does not add them into an unsupported portfolio total.

The server computes annualized expected loss as annual threat-event frequency multiplied by vulnerability multiplied by primary loss plus probability-weighted secondary loss. Independent triangular distributions are used for low/most-likely/high inputs, with 10,000 seeded draws; constant ranges remain constant. The report preserves the inputs, deterministic seed, formula, analytic mean and P10/P50/P90 uncertainty values. These percentiles describe uncertainty in annualized expected loss, not annual aggregate loss percentiles or value-at-risk. Independence and stable annual rates are assumptions to validate; AI does not supply missing financial factors. The five-point ordinal rating is reported separately and is never converted into money.

Export contents and interpretation

JSON preserves the report envelope, author, method/version, provider/model, scenario inputs, per-risk source snapshots, evidence references, input/output hashes, analysis, checked ratings, gaps and quantitative assumptions/results. CSV uses a lossless two-column field/value layout with indexed paths for nested risks and factors; spreadsheet formula prefixes are escaped. PDF presents readable methodology findings, ratings, scenario inputs, evidence checks, gaps, financial factors/results and provenance hashes across numbered pages; JSON retains the complete machine-readable source snapshots. Supplied markup is escaped. All three formats are downloadable from the same saved report and record an export audit event. Failed/stale item statuses and missing-data notices remain in exports.

Official references

- NIST SP 800-30 Rev. 1 (2012): https://csrc.nist.gov/pubs/sp/800/30/r1/final

- The Open Group Open FAIR risk-analysis publication: https://pubs.opengroup.org/security/o-ra/

- ISO/IEC 27005:2022 publication description: https://www.iso.org/standard/80585.html

- HHS/ONC SRA tool and its limitations: https://healthit.gov/privacy-security/security-risk-assessment-tool/

- FFIEC CAT sunset notice: https://www.ffiec.gov/news/press-releases/2024/an-09-29

- CISA Infrastructure Survey Tool: https://www.cisa.gov/resources-tools/services/infrastructure-survey-tool-ist

- CISA Cross-Sector Cybersecurity Performance Goals:
https://www.cisa.gov/cross-sector-cybersecurity-performance-goals

References checked November 6, 2026. These profiles are advisory adaptations, not official agency applications, examinations, certifications or licensed reproductions.

Deployment and runtime behavior

Assessment calls are synchronous and process the selected risks sequentially without a fixed risk-count ceiling, with a 90-second provider read timeout and at most one schema-repair retry per risk. Large local-model batches can therefore take longer in proportion to the number of selected risks. Operators must configure the TLS reverse proxy/request timeout for the selected batch size (allow up to approximately three minutes per risk for two provider timeouts), or use smaller batches. If the connection times out, check Saved reports before retrying: a completed server-side report may already exist. There is no background-job progress or cancellation API in this profile. Source context is bounded to linked-record limits; a report is not an exhaustive assessment of all organizational records.

Risk change history and independent remediation closure

Author: Shahryar Jahangir, Aniza Inc. Version 5.54.14.

View risk changes

Open **Risks**, choose **Manage**, then **Change history**. The history shows recorded creation, edits (including applied AI score changes) and resolution/closure. Expand a record to compare the available before and after fields. Refresh returns to the newest events. Previous and Next navigate in pages of 50. Back to risk retrieves the current record without triggering a new AI assessment.

The signed status is per event. **Verified** means the recorded event matches its configured audit HMAC. **Unsigned** means no signature was stored. **Not verified** means the historical signature cannot currently be checked. **Invalid** means the signature or stored payload is invalid; snapshot content is withheld. An individual valid signature does not prove the entire

history is complete. Missing historical fields are never reconstructed. PostgreSQL append-only privileges and external audit anchoring are separate deployment controls; SQLite history is not WORM storage.

API: `GET /api/risks/{risk_id}/history?limit=50&offset=0`. The API accepts 1-200 events per page. It uses the same selected-tenant risk-read access as the risk report. An inaccessible risk returns 404. This is a read-only view of existing committed audit records.

Close a remediation with an independent review

1. Create the finding and remediation. Assign its accountable owner.

2. Record corrective work and move the remediation to **ready_for_review**.

3. An independent authorized tester records a passing test on the finding's control after that readiness submission. The tester must not be the remediation creator or a recorded lifecycle participant.

4. Upload the retest's supporting files on the same control after readiness. File uploads use the existing evidence encryption provider. A URL/hash-only evidence registration does not satisfy the file requirement.

5. A tenant administrator or auditor who did not create or participate in the remediation opens **Remediations -> Transition**, chooses **closed**, selects the passing retest and 1-5 supporting files, and explains how those files support the result in the review note. Platform administrators still operate within their selected tenant.

6. The server checks the reviewer and tester identities, current readiness/version, control and tenant ownership, test result, timestamps, file availability, authenticated decryption and content hashes before committing. The closure audit record retains the exact retest, file hashes, reviewer, readiness timestamp and attestation.

The creator, any recorded non-closure lifecycle participant, and a named owner matching the current user's ID/email cannot close the remediation. Ownership is currently free text: use the actual email to identify a person; arbitrary group/display labels are not a directory identity. Unsigned legacy audit history uses its recorded actor IDs under existing access protections. Historical signed audit events must verify with the configured signing key; changing/removing that key blocks new closure until the original history can be verified. Missing current readiness/creation history blocks closure. Do not rewrite historical audit records to bypass this check. If legacy creation/readiness provenance is unavailable, investigate and create a new finding-linked remediation with complete provenance rather than fabricating old events. The old record remains preserved.

A failed, stale, unrelated or unavailable test/file cannot satisfy closure. A new readiness submission requires a subsequent retest and subsequent evidence uploads. Previously closed remediations are preserved. Reopening follows the existing lifecycle, with no automatic rewriting of previous closure decisions.

A human-entered passing result and uploaded file are reviewed observations. They do not prove that LexiGrid independently executed a technical test or establish compliance with an entire standard. The reviewer must examine the evidence and record an accurate conclusion.

API: `GET /api/remediations/{id}/closure-context` lists eligible tests/files for the finding's control. Existing `POST /api/remediations/{id}/transition` requests for `closed` must include `retest_id`, `evidence_ids`, `version`, `state` and `note`. Other transitions retain their existing request fields. These checks require no database migration, key replacement, or customer record conversion.

Risk acceptance, expiry and independent approvals

Author: Shahryar Jahangir, Aniza Inc. LexiGrid.

Request bounded risk acceptance

Create the risk as open or mitigating. In **Risks -> Manage -> Acceptance & expiry**, examine the current title, description, owner, category, score and version. Enter a substantive business rationale and an expiry in your local time. The browser converts it to an absolute UTC instant before submission. There is no default perpetual acceptance. One pending request is allowed per risk; reject an obsolete pending request before replacing it. A renewal can be requested while the previous acceptance is still current.

The request stores the exact risk fields and version, rationale, requester and expiry, bound to its committed audit event. It does not silently change the official score or status. Links to other controls, policies, evidence and assessments are not part of this core risk snapshot: review those separately and revise the risk when circumstances change.

Independently decide or revoke

Open **Risk Acceptance** for paginated pending decisions, recorded approvals, historical requests or re-review events. Open a risk and expand **Exact risk snapshot reviewed** before deciding. An authorized tenant administrator, risk manager or auditor may approve only when they are not the requester, a recorded risk author, or an identified accountable owner. Routing a request through another person does not remove the author restriction. Owners are identified by exact user ID/email and explicit owner-role stakeholders. Group names/free-text labels are not directory identities. Unknown historical authorship cannot be reconstructed automatically.

Choose **Approve exact risk until expiry** or **Reject request**, enter the independent review rationale, then confirm. Approval rechecks content, version, provenance, identity and expiry inside the transaction. A stale or already decided request cannot be approved. Approval sets status to accepted and increments the risk version without changing likelihood or impact. Requests, decisions and earlier superseded acceptances remain in history.

Revoke acceptance records a reason and returns the still-bound accepted risk to mitigating. A new approval supersedes prior approvals and resolves pending expiry review events for that risk. New acceptance requires a fresh independent decision; a recorded generic risk approval does not constitute acceptance.

Expiry and re-review

A dedicated API-process worker scans once per minute, independently of whether SMTP is configured or enabled. It starts with the API and resumes scanning after restart; multiple processes serialize changes through the risk row and current acceptance state. Linux PostgreSQL concurrency tests verify one expiry and one durable review event across independent worker transactions. There is no exactly-once email delivery claim.

At expiry, a still-bound accepted risk moves to mitigating, its version increments, and the same transaction records an expiry audit event and durable re-review item. Its score is retained. The worker queues existing opted-in risk notifications where configured; actual SMTP delivery depends on the existing notification service. Expired approval is ineffective immediately in the acceptance view even if the next scan has not yet run. Risk list status may await that scan. Old approvals for changed, closed or newly accepted risks are superseded rather than reopening those risks.

Use **Risk Acceptance -> Re-review required** to locate the follow-up. Reassess the risk and request fresh independent approval or continue mitigation. Successful new approval resolves the durable review item while preserving its audit trail. Records with invalid provenance fail closed and require administrator investigation. A tenant scan failure is logged with tenant ID and safe exception type; it does not stop scans of other tenants. A damaged record may block expiry processing for its tenant until investigated.

Operational setting: `LEXIGRID_ACCEPTANCE_WORKER=1` is the default. Explicitly setting it to 0 disables the automatic scan and requires a separately managed scanner. Run `.venv/bin/python -c 'from app.risk_acceptance import scan_all; print(scan_all())'` only with the installation's existing runtime environment securely loaded, including its original database and signing configuration. Do not copy credentials into command-line arguments. The API

acceptance view still evaluates expiry when the worker is stopped. Observe structured `risk.acceptance.*` events and investigate scan failures; application health alone does not prove the worker has completed a scan.

Edit, close and AI assessment

Creating a risk as accepted or setting an ordinary edited risk to accepted is rejected. To change accepted content or apply a new AI rating, first set the risk to open or mitigating, then make the change and request fresh acceptance. An unchanged save of an accepted risk preserves its version. Risk closure retains its separate resolution workflow and does not imply acceptance. Existing accepted risks are preserved; without current bound approval they display a review warning. No historical approval or missing fields are fabricated.

Native approvals and generic workflows

The **Approvals** workspace binds new risk, policy and finding requests to their exact tenant-owned content. **Binding status** distinguishes current, stale, legacy unbound and unverifiable records. Recorded approval and effective current approval are separate. Risk reports retain historical decisions while refusing to present stale approvals as the current approving actor.

Requesters, recorded content creators/editors and identified owners cannot approve via a different requester. Stale native approval requests must be rejected and recreated. A new policy publication requires both the unchanged reviewed policy version and matching request/decision audit provenance. Existing published policies are preserved; older unbound decisions cannot authorize a new publication.

Generic multi-step enterprise workflows also reject assigned creators, editors and identified owners; the initiator remains excluded. Approval rechecks the bound version/digest before deciding a step, and the governed transition rechecks it before consumption. Rejection remains available to close an obsolete pending run. No normal author override is provided. The current tenant-wide roles and free-text owner labels do not implement business-unit/object-level permissions or reconstruct unknown legacy authorship.

Audit control-owner independence

An identified control owner cannot issue a conclusive passed/failed or not-applicable safeguard review, nor finalize an audit containing their control. They may record an unresolved draft. A different audit creator/final reviewer remains required. Control identities are checked against the snapshot and current locked control versions; a changed control requires a fresh catalogue snapshot. This preserves existing finalized snapshots and their signed integrity. Ownership matching uses recorded user ID/email; arbitrary group/display labels require organizational identity governance outside this check. No automated independence exception is granted.

API

- `GET/POST /api/risks/{id}/acceptances` reads history or requests acceptance with risk_version, reason and timezone-aware expires_at.

- `POST /api/risks/{id}/acceptances/{acceptance_id}/decision` accepts version, decision (approved/rejected/revoked) and note.

- `GET /api/risk-acceptances?state=pending&limit=50&offset=0` lists tenant-scoped acceptance records.

- `GET /api/risk-acceptance-reviews?limit=50&offset=0` lists unresolved expiry reviews.

- Pagination supports 1-200 records per request; offset pagination does not impose a total record ceiling.

Records reuse existing tenant-isolated tables and append-only audit controls. There is no schema migration, key replacement, destructive conversion or automatic modification of legacy accepted risks. Signing provenance is verified

when configured; unsigned history is not WORM proof. Invalid signed requests and altered approval payloads cannot be relied on. Product checks do not establish certification or prove that a human-entered observation is true.